

Case Study – Importance of Forensics Readiness

Daniel Pereira
Departamento de Engenharia Informática
Coimbra, Portugal
uc2021237092@student.uc.pt

Rodrigo Rodrigues
Departamento de Engenharia Informática
Coimbra, Portugal
uc2022233032@student.uc.pt

Diogo Larangeira
Departamento de Engenharia Informática
Coimbra, Portugal
diogo.larangeira@student.uc.pt

Inês Tovar
Departamento de Engenharia Informática
Coimbra, Portugal
uc202225151@student.uc.pt

Abstract—Digital forensic readiness is a critical yet often neglected aspect of organizational security. This paper analyses the forensic readiness failures of VelocityCap, a high-frequency trading firm that suffered an unauthorized API-based diversion of 1.2 Million Euro. The digital crime scene was severely compromised due to unsynchronized clocks, locally stored logs, and destruction of volatile memory caused by an uninformed system reboot. Using ISO/IEC 27001:2022, ISO/IEC 27037:2012, RFC 3227, and NIST SP 800-86 as reference frameworks, this paper maps the control failures, evaluates evidence admissibility, and proposes a Forensic-by-Design architecture to prevent similar incidents.

Index Terms—Forensics Readiness, Digital Forensics, Incident Response, Evidence Integrity, Chain of Custody, Log Management, Memory Forensics, Clock Synchronization, WORM Storage, ISO/IEC 27001

I. INTRODUCTION

The financial sector has become increasingly dependent on digital infrastructures, making it a prime target for sophisticated cyberattacks. High-frequency trading platforms, payment gateways, and automated API-driven systems process millions of transactions daily, and any security breach can result in significant financial and reputational damage.

However, many organizations focus their security investments on prevention while neglecting forensic readiness — the capacity to collect, preserve, and present digital evidence after an incident occurs. As Rowlingson (2004) established, forensic readiness is not about responding to incidents, but about being prepared before they happen. Without this preparation, even well-secured organizations may find themselves unable to investigate breaches or pursue legal accountability.

This paper analyses the case of VelocityCap, a high-frequency trading firm that suffered an unauthorized API-based diversion of €1.2 million. The objective is not to identify the attacker, but to evaluate the firm’s forensic readiness failures and their implications. The analysis is structured around three tasks: evaluating evidence integrity, mapping control gaps against ISO/IEC 27001:2022, and proposing a Forensic-by-Design architecture.

The remainder of this paper is organized as follows: Section II presents the theoretical background; Section III analyses

evidence integrity; Section IV maps the identified control gaps; and Section V proposes a redesigned forensic architecture.

II. STATE-OF-THE-ART: FORENSICS READINESS

A. Definition and Origin of the Concept

The concept of Forensics Readiness was formalized by Rowlingson in 2004 in the paper “A Ten Step Process for Forensic Readiness”, where it is defined as an organization’s ability to maximize the collection of digital forensic evidence at minimal cost and operational impact before an incident occurs [1]. This definition is particularly relevant because it shifts the focus from reactive response to proactive preparation — the organization does not wait for an incident to begin thinking about evidence.

The paper established the ten fundamental steps that an organization should follow, among which the most notable are: defining risk scenarios, identifying potentially relevant sources of evidence, training personnel responsible for evidence collection, and creating incident response policies that preserve the integrity of evidence. Rowlingson further argues that forensic readiness is a strategic investment: prepared organizations significantly reduce investigation costs and increase the likelihood of successful legal accountability [1].

Later, Sachowski, in 2019, expanded this concept in the context of cloud environments and hybrid infrastructures, proposing that Forensic-by-Design — the integration of forensic capabilities from the system architecture phase — represents the natural evolution of traditional Forensics Readiness [2].

B. Standards and Frameworks

Several international standards have formalized the requirements for forensic readiness, creating a normative framework that organizations should follow.

RFC 3227 (2002) — Guidelines for Evidence Collection and Archiving — is a technical document that serves as a reference for information security and digital forensics professionals on how to collect, preserve, and store digital evidence in a manner that is both reliable and legally admissible. A key principle highlighted in RFC 3227 is the order of volatility, which prioritizes collecting the most ephemeral data first [3]:

- 1) CPU and cache registers
- 2) RAM memory
- 3) Temporary files and operating system state
- 4) Hard drive and persistent storage
- 5) Remote logs and network data

ISO/IEC 27037:2012 — Guidelines for Digital Evidence — defines the principles for the identification, collection, acquisition, and preservation of digital evidence [4]. It establishes that evidence must be collected in a way that ensures its integrity, authenticity, and chain of custody. The standard also introduces the concept of the First Responder, defining the skills and responsibilities of the person who first contacts the digital scene.

ISO/IEC 27001:2022 — the most widely adopted information security management standard globally — includes controls directly related to forensic readiness, namely A.8.15 (Logging), A.8.17 (Clock Synchronization), and A.8.1 (User Responsibilities) [5]. Non-compliance with these controls compromises not only forensic investigations but also the organization’s overall security posture.

NIST SP 800-86 — Guide to Integrating Forensic Techniques into Incident Response — complements the ISO standards by providing practical guidance on how to integrate forensic techniques into incident response processes [6]. NIST emphasizes that the preservation of volatile memory should be the first step in any incident response, before any system reboot or modification.

C. Digital Evidence and Judicial Admissibility

The admissibility of digital evidence in court is conditioned by a set of technical and legal requirements that the literature has been consolidating. Carrier and Spafford (2003) argue that the forensic validity of evidence depends on three pillars: authenticity (the evidence is what it claims to be), integrity (it has not been altered since collection), and reliability (the collection process is reproducible and auditable) [7].

Time synchronization is a factor that is often underestimated but crucial. Casey (2011) demonstrates that clock discrepancies between systems—even of just a few seconds—can be enough to invalidate event correlations in court, since the defense may argue that the logical sequence of events cannot be established with certainty [8].

The use of cryptographic hashing (typically SHA-256 or SHA-3) for integrity verification is now considered standard practice. The function $H(\text{Original Evidence}) = H(\text{Copied Evidence})$ ensures that any tampering, even minimal, is detectable—making the forensic evidence defensible in court [4] [6].

D. Preservation of Volatile Memory (Live Forensics)

The increasing sophistication of cyberattacks has led to the development of Live or Memory Forensics, which focuses on acquiring evidence from running systems. Ligh et al. (2014) extensively document that critical data—such as encryption keys, active network sessions, malicious processes, and in-memory credentials—exist only in RAM and are lost upon

reboot [9]. Tools like the open-source Volatility Framework and Magnet RAM Capture allow forensic RAM imaging without disrupting the system and are now recommended before any actions that alter system state.

E. Immutable Storage and WORM

The protection of log integrity in real time is a rapidly evolving area. The WORM (Write Once, Read Many) model, applied to centralized logging systems, ensures that records cannot be modified or deleted after being written—even by users with administrative privileges [5]. Solutions such as AWS CloudTrail with S3 Object Lock, Azure Immutable Blob Storage, or SIEM platforms like Splunk and IBM QRadar implement this paradigm and are widely adopted in regulated sectors such as finance. Centralizing logs on a dedicated, immutable server separate from monitored systems is now considered a minimum requirement for forensics readiness—any log stored locally on a compromised system is forensically and legally inadequate.

III. ANALYSE THE EVIDENCE INTEGRITY

A. Timestamp Correction

The Web Server Clock was not synchronized via NTP. To obtain the corrected timestamps, 125 seconds were added to each Web Server log entry. Applying this correction, the €1,200,000 transfer recorded at 01:58:45 (local time) corresponds to 02:00:50 UTC. Similarly, the authentication token request at 01:57:40 corrects to 01:59:45 UTC, and the rate limit bypass at 01:58:12 corrects to 02:00:17 UTC.

TABLE I: Corrected Event Timeline

Event	Original	Corrected	Source
Auth token request (Admin_Internal)	01:57:40	01:59:45	Web Server
Firewall: connection accepted	02:00:01	02:00:01	Firewall
Firewall: 2nd connection accepted	02:00:05	02:00:05	Firewall
Rate limit bypassed (Session 9982x)	01:58:12	02:00:17	Web Server
Transfer €1,200,000 (POST)	01:58:45	02:00:50	Web Server
DB COMMIT confirmed	02:01:10	02:01:10	Database
Connection terminated	02:15:30	02:15:30	Firewall
Reboot by administrator	02:20:05	02:20:05	DB/System

As shown in Table I, a corrected timeline of all events across all sources is presented, ordered by corrected UTC timestamp. However, it is important to note that the Web Server contained two overlapping errors: an incorrect timezone configuration (-0800 instead of UTC) and an estimated clock drift of -125 seconds. This means that the correction applied is not a simple 125-second adjustment, but rather a two-factor

correction involving both a timezone conversion and a drift compensation. Any post-hoc correction involving two sources of uncertainty significantly weakens the evidentiality value of the Web Server logs, as the defense may challenge the accuracy of either factor independently. This compounding of errors makes the correlation between Web Server and Firewall events particularly unreliable for judicial purposes.

B. Event Correlation Analysis

As shown in Table I, the corrected timestamps reveal a temporally coherent sequence: the firewall connection from 185.225.69.10 was accepted at 02:00:01 UTC, followed by the €1,200,000 POST request at 02:00:50 UTC, and confirmed by the database COMMIT at 02:01:10 UTC. This chronological consistency is necessary to establish causality, but it is not sufficient to prove it.

Two critical gaps prevent a definitive causal link from being established. First, the Firewall log confirms that a connection was accepted from the attacker's IP, but does not confirm that this specific connection issued the POST request — there is no session identifier linking the firewall entry to the Web Server log.

Second, Exhibit 2 was stored as a writable local file on the compromised system, meaning its contents could have been altered by any user with root access — whether an **external attacker escalating privileges or an insider**, as suggested by the Slack logs. Without a cryptographic **hash or WORM storage** guaranteeing log integrity, the Web Server logs cannot be trusted as unmodified, and the correlation between the firewall entry and the POST request cannot be forensically confirmed.

C. Evidence admissibility

The term **estimated** in the audit note represents the central forensic and legal problem. In digital forensics, the admissibility of technical evidence follows frameworks such as the Daubert Standard in the United States or equivalent principles in European jurisdictions [10], all of which require that evidence be based on a verifiable and reproducible methodology, derived from accepted and documented techniques, and associated with a known and measurable error rate [8].

The statement "*estimated clock drift is around -125 seconds*" fails to meet these requirements on three grounds.

First, there is no record of when the drift was measured, by whom, or using which tool, making independent verification impossible.

Second, clock drift on a system without NTP synchronization is not linear — it varies with CPU load, temperature, and virtualization overhead, meaning the actual drift at 02:00 UTC may have differed significantly from the estimated value.

Third, if the measurement was taken after the system reboot, the clock state during the incident no longer exists and may not accurately reflect the drift at the time of the transfer.

As a practical consequence, a defense attorney could argue that the entire corrected timeline is speculative, potentially leading the court to declare the Web Server logs inadmissible.

Should this occur, the causal link between the firewall-logged IP address and the POST request would formally collapse, making prosecution based solely on these logs unfeasible.

D. Can the Attacker be Proven Responsible for the POST Request?

Even with the corrected timeline, it is not possible to conclusively prove that the host at 185.225.69.10 performed the €1,200,000 POST request. Several critical evidentiary gaps prevent this attribution.

First, there is no direct link between the IP address and the POST request. While the Firewall confirms that 185.225.69.10 connected to the API Gateway, and the Web Server confirms that a POST was performed using an Admin token, no log entry explicitly associates that IP with that specific request, as the Web Server logs do not record the source IP of each individual request.

Second, the *Admin_Internal* token used in the POST may have been compromised prior to the attack through an entirely different vector, such as phishing, credential theft, or insider collaboration. The host at 185.225.69.10 may have simply used a previously stolen token.

Third, the integrity of the Web Server logs cannot be verified. Exhibit 2 is a locally stored, writable file. Without a cryptographic hash computed at the time of log generation, there is no way to prove the logs were not modified between the incident and the moment investigators collected them. The defense only needs to raise this doubt — it does not need to prove tampering occurred.

Fourth, 185.225.69.10 is identified by the Firewall as a TOR exit node, meaning it is the last node in a TOR circuit. The true origin of the connection is completely unknown and untraceable. Even if it could be proven that this IP executed the POST, it cannot be attributed to a specific individual or machine.

Finally, the system reboot at 02:20:05 destroyed all volatile memory, including active network connections and session data that could have confirmed which IP was associated with the active session at the time of the POST request. This evidence is now permanently unrecoverable.

IV. CONTROL GAP MAPPING

The incident at VelocityCap reveals a significant disconnect between operational availability and forensic integrity. The following analysis maps the infrastructure's failure to provide a post-mortem trail to specific non-conformances within the ISO/IEC 27001:2022 framework.

A. Critical Failures in ISO/IEC 27001:2022 Controls

The infrastructure failed to meet the baseline requirements for a secure, auditable environment, specifically regarding the following controls:

- A.8.17 Clock Synchronization: The Web Server log (Exhibit 2) recorded a database query modification at 01:58:45 Local Time. However, the server was not utilizing the Network Time Protocol (NTP), resulting in

a suspected clock drift of approximately -125 seconds. This discrepancy makes it mathematically difficult to synchronize the Web Server events with the Firewall logs, which use the UTC standard. Without synchronized clocks, establishing a definitive timeline of the attack becomes a matter of estimation rather than proof.

- A.8.15 Logging: VelocityCap failed to implement a centralized logging architecture. By storing logs as "Writable Local Files" on the Application Gateway (API GW-Nginx), the firm allowed for a single point of failure where a compromised system could have its own history erased by the intruder.
- A.8.1 User Responsibilities regarding evidence: The System Administrator, prioritizing service restoration over evidence preservation, rebooted the server at 02:20:05 UTC to address high CPU usage. This action directly contravenes the responsibility to preserve the state of a "Digital Crime Scene" during an active breach.

B. Vulnerability of Local Log Storage

The reliance on local, writable logs (Exhibit 2) represents a "Major Non-Conformance" under ISO/IEC 27001 A.8.15. In a typical exploit scenario, the first action an attacker performs after gaining root access is the manipulation or deletion of local log files to scrub their "digital fingerprints".

By allowing logs to remain writable on the breached host, the integrity of the entire Evidence Portfolio is compromised. To mitigate this, a Forensic-by-Design architecture must employ a dedicated Forensic Platform utilizing Write Once, Read Many (WORM) storage. In such a configuration, log data is streamed in real-time to an external, immutable repository, ensuring that even a root-level compromise of the application server cannot result in the alteration of recorded history.

C. The "Silent Void": Erasure of Volatile Evidence

The most damaging blow to the investigation was the server reboot at 02:20:05 UTC. While intended to restore functionality, this process permanently purged the server's Random Access Memory (RAM) before a forensic image could be captured. This created a "silent void" where the most transitional and revealing artifacts of the 1.2 Million Euro diversion were lost.

TABLE II: Volatile Artifacts and Lost Evidence

Artifact Category	Description of Lost Evidence
Active Network State	List of all established socket connections to the malicious IP 185.225.69.10 at the time of the transfer.
Process Memory	The memory space of the xmrig miner, which could reveal configuration files and wallet addresses.
Cryptographic Keys	Temporary session keys held in RAM that would have allowed investigators to decrypt the captured API traffic.
Kernel Structures	Loaded modules or rootkits that might have hidden the unauthorized API diversion from standard monitoring tools.
Authentication Tokens	Active Admin session tokens linking the TOR connection to the POST request.

V. THE READINESS ARCHITECTURE

The redesign focuses on transforming the infrastructure into a "reliable witness" through automated evidence preservation and integrity controls.

A. Network Segmentation and Forensic Isolation

The infrastructure is partitioned into isolated tiers to contain breaches and facilitate live analysis:

- **Micro-segmentation:** Separation of the Network Edge, API Gateway, and Database layers into distinct trust zones.
- **Forensic Quarantine VLAN:** A dedicated segment where compromised hosts are logically moved. This allows for live investigation and memory acquisition without severing active network sockets.
- **Deep Packet Inspection (DPI) for TOR:** The network edge is configured to alert and log all traffic from TOR exit nodes, specifically targeting the anonymity vectors used in the incident.

B. Immutable Logging and Blockchain Integrity

To solve the issue of logs being stored in "Writable Local Files," the following strategy is implemented:

- **Centralized WORM Storage:** Logs are streamed in real-time to a remote, Write-Once-Read-Many (WORM) repository.
- **Blockchain-based Log Chaining:** Each log entry is cryptographically linked to the previous one using a hash-chain. This ensures that any attempt to delete or modify a record is mathematically detectable.
- **Integrity Verification:** Periodic validation of the evidence chain is performed using the hashing principle: $H(Evidence_{Original}) = H(Evidence_{Copy})$.

C. Host Integrity and Application Control

To prevent the execution of unauthorized software like cryptocurrency miners:

- **Application Whitelisting (HIDS):** Only pre-approved binaries are permitted to run. Any unauthorized process execution triggers an immediate forensic alert.
- **File Integrity Monitoring (FIM):** Critical system files and database indices are monitored for unauthorized changes, addressing threats from both external attackers and rogue administrators.

D. Temporal Synchronization

To eliminate the "clock drift" that compromises timeline correlation:

- **Unified Stratum-1 NTP:** All infrastructure nodes synchronize to a single, trusted time source.
- **UTC Standardization:** Mandatory use of UTC across all log sources to ensure seamless cross-platform analysis.

E. Automated memory snapshot triggers

Automated memory snapshot triggers — when anomalous behavior is detected (e.g., CPU spike, unauthorized process), the system automatically captures a RAM image to WORM storage before any human intervention occurs.

REFERENCES

- [1] R. Rowlingson, "A Ten Step Process for Forensic Readiness," *International Journal of Digital Evidence*, vol. 2, Jan. 2004.
- [2] J. Sachowski, *Implementing Digital Forensic Readiness: From Reactive to Proactive Process*, 2nd ed., CRC Press, 2019.
- [3] D. Brezinski e T. Killalea, "RFC 3227: Guidelines for Evidence Collection and Archiving," IETF, Feb. 2002.
- [4] ISO/IEC 27037:2012, *Information Technology — Security Techniques — Guidelines for Identification, Collection, Acquisition and Preservation of Digital Evidence*, ISO, 2012.
- [5] ISO/IEC 27001:2022, *Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements*, ISO, 2022.
- [6] NIST, SP 800-86: *Guide to Integrating Forensic Techniques into Incident Response*, NIST, Aug. 2006.
- [7] B. Carrier e E. Spafford, "Getting Physical with the Digital Investigation Process," *International Journal of Digital Evidence*, vol. 2, 2003.
- [8] E. Casey, *Digital Evidence and Computer Crime*, 3rd ed., Academic Press, 2011.
- [9] M. Ligh et al., *The Art of Memory Forensics*, Wiley, 2014.
- [10] *Daubert v. Merrell Dow Pharmaceuticals, Inc.*, 509 U.S. 579 (1993).